



АКАДЕМИЯ
КОДЕБАЙ

ПРОФЕССИЯ ПЕНТЕСТЕР



[DIRB](#) - это сканер каталогов, который ищет на веб-серверах скрытые файлы, каталоги и страницы. Это бесплатная утилита с открытым исходным кодом, входящая в состав дистрибутива Kali Linux, популярной операционной системы для тестирования на проникновение и этического взлома. DIRB можно использовать для обнаружения типичных папок и файлов веб-сервера, таких как страницы администратора, файлы резервных копий и файлы конфигураций. Он работает, отправляя HTTP-запросы на сервер, и анализирует ответы, чтобы определить существование файла или каталога.

Пример атаки на testphp.vulnweb.com с использованием стандартного списка слов:

```
(kali@kali)-[~]
$ dirb http://testphp.vulnweb.com

DIRB v2.22
By The Dark Raver

START_TIME: Mon Nov 11 17:34:48 2024
URL_BASE: http://testphp.vulnweb.com/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

— Scanning URL: http://testphp.vulnweb.com/ —
⇒ DIRECTORY: http://testphp.vulnweb.com/admin/
+ http://testphp.vulnweb.com/cgi-bin (CODE:403|SIZE:276)
+ http://testphp.vulnweb.com/cgi-bin/ (CODE:403|SIZE:276)
+ http://testphp.vulnweb.com/crossdomain.xml (CODE:200|SIZE:224)
⇒ DIRECTORY: http://testphp.vulnweb.com/CVS/
+ http://testphp.vulnweb.com/CVS/Entries (CODE:200|SIZE:1)
+ http://testphp.vulnweb.com/CVS/Repository (CODE:200|SIZE:8)
+ http://testphp.vulnweb.com/CVS/Root (CODE:200|SIZE:1)
+ http://testphp.vulnweb.com/favicon.ico (CODE:200|SIZE:894)
⇒ Testing: http://testphp.vulnweb.com/health
```

Существует множество ситуаций, когда нам необходимо извлечь файлы определенного расширения на целевом сервере. В этом случае мы можем использовать параметр `-X`. Этот параметр принимает расширение файла, а затем ищет файлы указанного расширения на целевом сервере:

```
(kali@kali)-[~]
$ dirb http://testphp.vulnweb.com -X .php

DIRB v2.22
By The Dark Raver

START_TIME: Mon Nov 11 17:45:04 2024
URL_BASE: http://testphp.vulnweb.com/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
EXTENSIONS_LIST: (.php) | (.php) [NUM = 1]

GENERATED WORDS: 4612

— Scanning URL: http://testphp.vulnweb.com/ —
⇒ Testing: http://testphp.vulnweb.com/_css.php
```

Для сохранения результата сканирования можно использовать параметр `-o`:

```
(kali@kali)-[~]  
$ dirb http://testphp.vulnweb.com -X .php -o result.txt  
  
_____  
DIRB v2.22  
By The Dark Raver  
_____  
  
OUTPUT_FILE: result.txt  
START_TIME: Mon Nov 11 17:49:47 2024  
URL_BASE: http://testphp.vulnweb.com/  
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt  
EXTENSIONS_LIST: (.php) | (.php) [NUM = 1]  
  
_____  
  
GENERATED WORDS: 4612  
  
—— Scanning URL: http://testphp.vulnweb.com/ ——  
■→ Testing: http://testphp.vulnweb.com/_images.php
```

Также можно использовать параметр `-N` для того, чтобы игнорировать ответы с определенным кодом:

```
(kali@kali)-[~]  
$ dirb http://testphp.vulnweb.com -N 302  
  
_____  
DIRB v2.22  
By The Dark Raver  
_____  
  
START_TIME: Mon Nov 11 17:54:21 2024  
URL_BASE: http://testphp.vulnweb.com/  
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt  
OPTION: Ignoring NOT_FOUND code → 302  
  
_____  
  
GENERATED WORDS: 4612  
  
—— Scanning URL: http://testphp.vulnweb.com/ ——  
■→ Testing: http://testphp.vulnweb.com/_vti_inf
```

По умолчанию DIRB сканирует каталоги рекурсивно. Это означает, что он сканирует каталог, а затем сканирует внутри этого каталога. В некоторых сценариях, когда времени недостаточно, мы можем настроить DIRB не сканировать рекурсивно. Этого можно добиться с помощью параметра `-r`:

```
(kali@kali)-[~]
$ dirb http://testphp.vulnweb.com -r

DIRB v2.22
By The Dark Raver

START_TIME: Mon Nov 11 18:03:01 2024
URL_BASE: http://testphp.vulnweb.com/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
OPTION: Not Recursive

GENERATED WORDS: 4612

— Scanning URL: http://testphp.vulnweb.com/ —
→ Testing: http://testphp.vulnweb.com/_media
```

Для сканирования также можно использовать свои списки слов. В качестве примера мы можем создать свой список слов с помощью `html2dic` и использовать его для сканирования (`html2dic` – генерирует списки слов из HTML-страниц):

```
(kali@kali)-[~]
$ wget http://testphp.vulnweb.com/
--2024-11-11 18:10:04-- http://testphp.vulnweb.com/
Resolving testphp.vulnweb.com (testphp.vulnweb.com)... 44.228.249.3
Connecting to testphp.vulnweb.com (testphp.vulnweb.com)|44.228.249.3|:80 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: unspecified [text/html]
Saving to: 'index.html'

index.html          [ ↔ ] 4.84K --.-KB/s in 0s
2024-11-11 18:10:04 (98.4 MB/s) - 'index.html' saved [4958]

(kali@kali)-[~]
$ html2dic index.html > wordlist.txt
```

```
(kali@kali)-[~]
$ dirb http://testphp.vulnweb.com wordlist.txt

DIRB v2.22
By The Dark Raver

START_TIME: Mon Nov 11 18:17:31 2024
URL_BASE: http://testphp.vulnweb.com/
WORDLIST_FILES: wordlist.txt

GENERATED WORDS: 109

— Scanning URL: http://testphp.vulnweb.com/ —
⇒ DIRECTORY: http://testphp.vulnweb.com/AJAX/
→ Testing: http://testphp.vulnweb.com/into
```

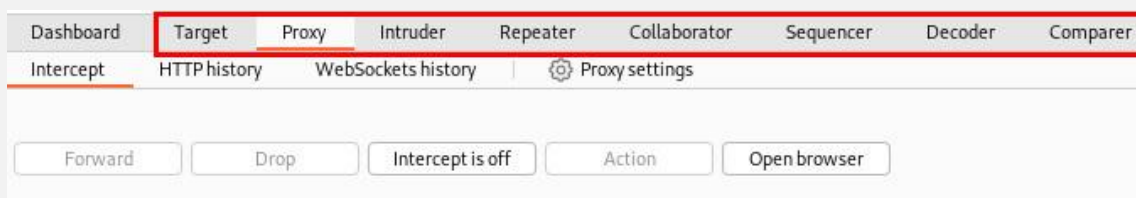
Burp Suite

[Burp Suite](#) — это швейцарский армейский нож для специалистов по безопасности. Он не только позволяет проводить глубокий ручной анализ, но и сочетает автоматизированные методы для перечисления и анализа веб-приложений.

Burp разработан компанией PortSwigger и распространяется в трех редакциях:

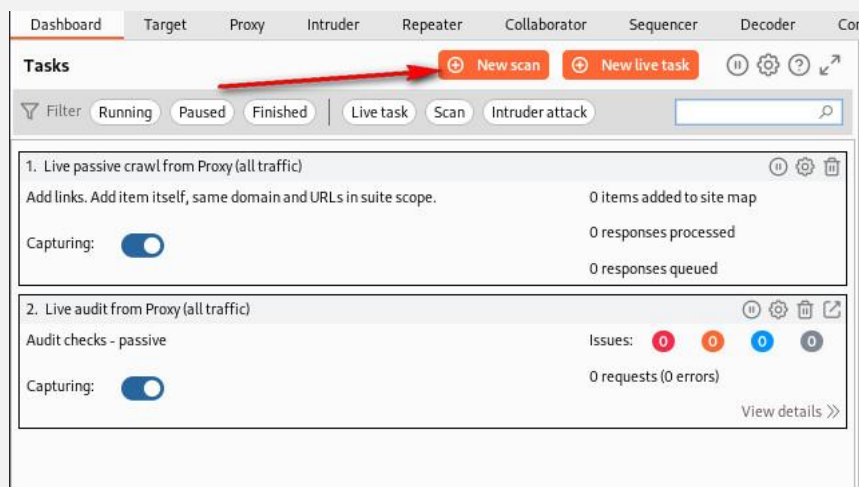
- Burp Free
- Burp Professional
- Burp Enterprise Edition

По своей сути Burp - это локальный веб-прокси, который позволяет перехватывать, проверять и изменять HTTP/S запросы между браузером пользователя и целевым веб-сайтом. Пока пользователь перемещается по веб-приложению, инструмент получает подробную информацию обо всех посещенных страницах, скриптах, параметрах и других компонентах. Трафик между браузером и сервером можно анализировать и изменять и многократно повторять отправку запросов. Различные инструменты, входящие в состав Burp Suite, находятся во вкладках:



- Target: Этот инструмент позволяет объединить все ресурсы веб-приложения, тем самым облегчая работу пользователя на протяжении всего теста безопасности.
- Proxy: Это основной компонент инструмента, который позволяет перехватывать и модифицировать весь веб-трафик.

- **Scanner:** Сканер безопасности веб-приложений, доступный в версии Professional:



- **Intruder:** Burp Intruder позволяет настраивать и автоматизировать веб-запросы, повторяя отправку одного и того же запроса с разным содержимым.
- **Repeater:** Простой, но мощный инструмент, который можно использовать для ручной модификации и повторной отправки запросов.
- **Sequencer:** Burp Sequencer - идеальный инструмент для проверки случайности и предсказуемости токенов безопасности, файлов cookie и многого другого.
- **Decoder:** Позволяет кодировать и декодировать данные, используя различные схемы кодирования. Например, Base64 -> Plain Text и т.д.
- **Comparer:** Визуальный инструмент сравнения, который можно использовать для обнаружения изменений между веб-страницами.

[Nikto](#) - это бесплатный сканер уязвимостей командной строки, который проверяет веб-серверы на наличие устаревшего серверного программного обеспечения и других проблем. Он выполняет общие и специфические для каждого типа сервера проверки. Первая версия была выпущена 27 декабря 2001 года. Несмотря на свой "возраст", Nikto - отличный инструмент, который может быть использован в сочетании с другими сканерами, такими как Burp Scanner, Wapiti и т.д.



Синтаксис для запуска сканирования выглядит следующим образом:

`nikto -h <Домен или IP-адрес>`

```
(kali㉿kali)-[~]
$ nikto -h testphp.vulnweb.com
- Nikto v2.5.0

+ Target IP: 44.228.249.3
+ Target Hostname: testphp.vulnweb.com
+ Target Port: 80
+ Start Time: 2024-11-11 18:26:06 (GMT-5)

+ Server: nginx/1.19.0
+ /: Retrieved x-powered-by header: PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
```

Также можно указать порты для сканирования:

```
(kali㉿kali)-[~]
$ nikto -h testphp.vulnweb.com -p 25,22,3306
- Nikto v2.5.0
```

Если на сайте используется протокол HTTPS, то можно задать параметр `-ssl` для отображения подробной информации связанной с HTTPS:

```
(kali㉿kali)-[~]
$ nikto -h testphp.vulnweb.com -ssl
- Nikto v2.5.0
```

Для создания отчета необходимо использовать параметры `-output` и `-Format`:

```
(kali㉿kali)-[~]
$ nikto -h testphp.vulnweb.com -output report.html -Format html
- Nikto v2.5.0

+ Target IP: 44.228.249.3
+ Target Hostname: testphp.vulnweb.com
+ Target Port: 80
+ Start Time: 2024-11-11 18:37:47 (GMT-5)

+ Server: nginx/1.19.0
+ /: Retrieved x-powered-by header: PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
```

Отчет:

testphp.vulnweb.com / 44.228.249.3 port 80	
Target IP	44.228.249.3
Target hostname	testphp.vulnweb.com
Target Port	80
HTTP Server	nginx/1.19.0
Site Link (Name)	http://testphp.vulnweb.com:80/
Site Link (IP)	http://44.228.249.3:80/
URI	/
HTTP Method	GET
Description	/: Retrieved x-powered-by header: PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1.
Test Links	http://testphp.vulnweb.com:80/ http://44.228.249.3:80/
References	
URI	/
HTTP Method	GET
Description	/: The anti-clickjacking X-Frame-Options header is not present.
Test Links	http://testphp.vulnweb.com:80/ http://44.228.249.3:80/
References	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
URI	/
HTTP Method	GET
Description	/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a browser, without the help of a renderer.
Test Links	http://testphp.vulnweb.com:80/ http://44.228.249.3:80/
References	https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
URI	/clientaccesspolicy.xml
HTTP Method	GET
Description	/clientaccesspolicy.xml contains a full wildcard entry.
Test Links	http://testphp.vulnweb.com:80/clientaccesspolicy.xml

Параметр -Format поддерживает следующие форматы для генерации отчетов:

- CSV
- HTML
- XML
- NBE
- JSON
- SQL

Команды, используемые в уроке:

```
kali@kali:~$ dirb http://www.megacorpone.com -r -z 10
```

```
kali@kali:~$ burpsuite
```

```
kali@kali:~$ nikto -Help
```

```
kali@kali:~$ nikto -host=http://testhtml5.vulnweb.com/#/contact -maxtime=30s -o=report.html
```